

Instructions:

Prompting an active incident response scenario at Permalink Software, the SOC team noticed an unusual spike in traffic from one of their endpoints, communicating with a known malicious IP address. This activity was flagged by the network intrusion detection system (NIDS) and correlated with other indicators of compromise found in threat intelligence feeds.

Your task is to use your knowledge of the MITRE ATT&CK framework and TTPs to help guide the team through identifying and reconstructing the attack kill chain. By doing so, the SOC can better understand the nature of the compromise and formulate a response plan.

Q1 The investigation revealed that a large spike in network traffic originated from an external IP address. The majority of this traffic was generated by a suspicious user-agent string: Mozilla/5.0 (compatible; Nmap Scripting Engine;) and appears to be aimed at identifying vulnerabilities. What is the ID of this specific sub-technique?

T1595.002

Q2 What is the name of the main technique this falls under?

Active Scanning

Q3 The SOC later discovered that the adversary exploited one of the organization's external software applications through an SQL injection vulnerability. What is the MITRE technique ID that led to the attacker's initial access?

T1190

Q4 It was later discovered that the sqlmap tool was used to automate the process of detecting and exploiting the SQL injection vulnerability. What is the MITRE ID pertaining to this piece of software?

S0225

Q5 After achieving remote code execution through the SQL injection vulnerability, the attacker created a remote reverse shell on the server by initiating a cmd.exe process. What sub-technique ID does this relate to?

T1059.003

Q6 The attacker escalated privileges by impersonating an administrator user's security token and abusing the SeImpersonatePrivilege. According to MITRE, what is one of the API calls that can be monitored to detect this behavior?

DuplicateToken

Q7 During the initial live incident response triage, a responder noticed that an existing Windows service had its image path modified to point to the attacker's malicious reverse shell payload - likely to establish persistence. What is the ID of this sub-technique?

T1543.003

Q8 Around the same timeframe, endpoint logs in the SIEM reported that the system's Endpoint Detection and Response (EDR) tool was turned off and disabled. What sub-technique ID is this event likely referring to?

T1685

Q9 The ccf32 software was transferred to the host shortly after the initial compromise. What tactic is this software likely used for?

Collection

Q10 After staging sensitive data, files, and intellectual property, the attacker exfiltrated the data by pushing it to a public GitHub repository. What mitigation ID could the organization have implemented to prevent the use of unauthorized external services?

M1021

Q11 To complete the adversary's Actions on Objectives, the organization's public-facing corporate website was modified to display propaganda messages during the attack. What is the full sub-technique ID of this attack?

T1491.002

Challenge URL

<https://challenges.malwarecube.com/#/c/c5620534-6450-4f97-9ccb-1644fc3ebc8e>